New Threat Model

Owner: amassine
Reviewer: review
Contributors:
Date Generated: Sun Nov 01 2026

Executive Summary

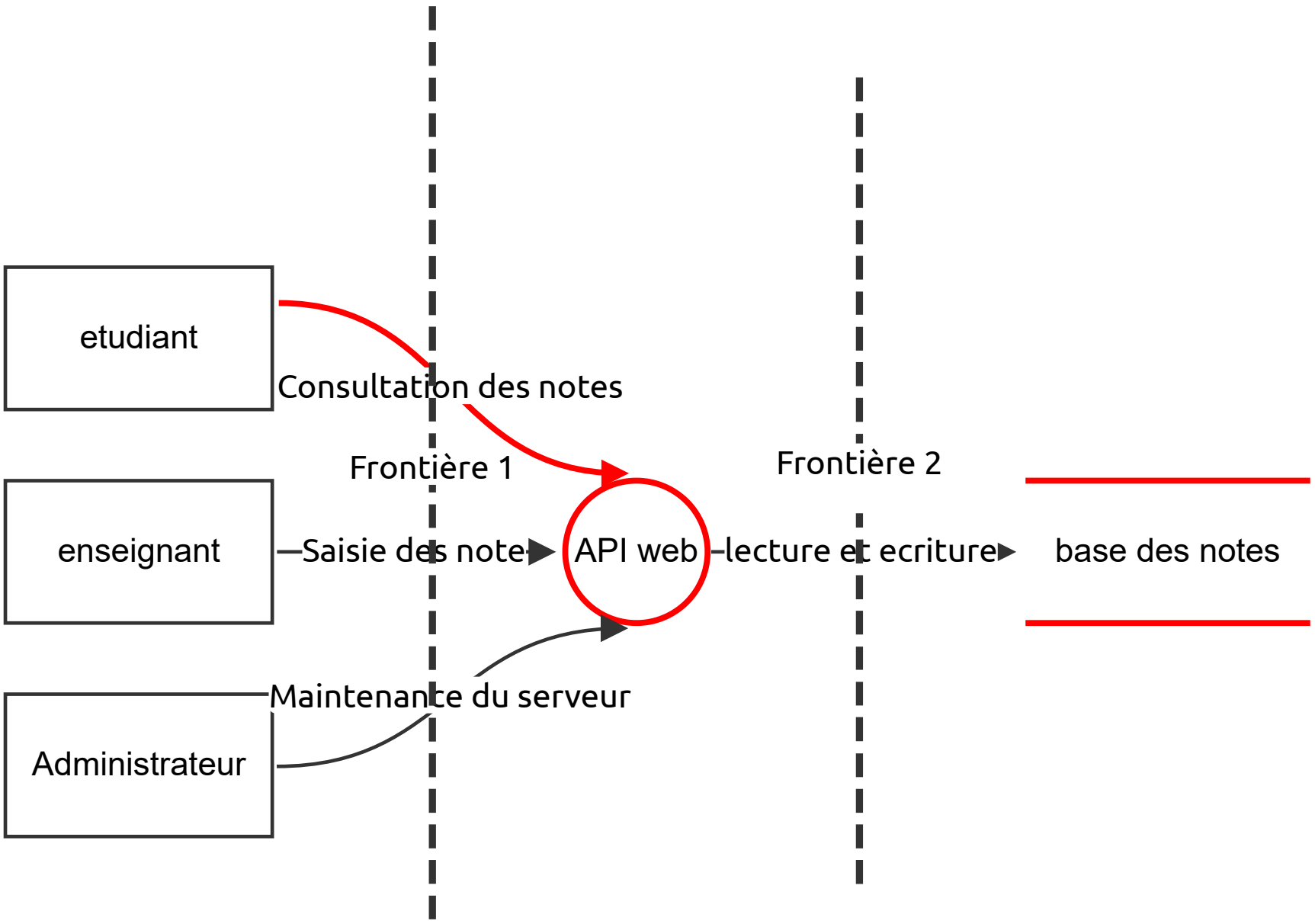
High level system description

Not provided

Summary

Total Threats	8
Total Mitigated	0
Total Open	8
Open / Critical Severity	0
Open / High Severity	5
Open / Medium Severity	3
Open / Low Severity	0

flux de donnes



flux de donnes

etudiant (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

enseignant (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Administrateur (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

base des notes (Store)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
7	Accès direct à notes.db	Information disclosure	High	Open		Quelqu’un avec accès au serveur copie le fichier et lit toutes les notes.	Permissions strictes sur le fichier, accès administrateur limité
8	Suppression ou corruption de la base	Denial of service	Medium	Open		Perte ou altération du fichier notes.db.	Sauvegardes régulières

API web (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
3	Usurpation d’identité	Spoofing	High	Open		Sans authentification, n'importe qui peut se faire passer pour un enseignant	Jetons + utilisateur_connecte().
4	Injection SQL	Tampering	High	Open		La recherche et la modification concatènent l’entrée dans la requête SQL.	Requêtes paramétrées
5	Élévation de privilèges	Elevation of privilege	High	Open		Un étudiant ou un enseignant d’un autre module modifie une note.	Contrôle du rôle et du module (403)
6	Pas de traçabilité	Repudiation	Medium	Open		Un enseignant peut nier avoir modifié une note.	Journaliser qui modifie quoi et quand

Maintenance du serveur (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Consultation des notes (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
1	Interception des notes en transit	Information disclosure	High	Open		Les notes passent par Internet depuis le téléphone ; un attaquant sur le même réseau Wi-Fi peut les lire.	Imposer HTTPS (TLS) pour toutes les communications.
2	Modification de la requête en route	Tampering	Medium	Open		Un attaquant modifie la requête (ex. change le nom de l'étudiant) avant qu'elle n'arrive à l'API.	HTTPS + validation des données côté serveur.

lecture et ecriture (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Saisie des note (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations